OS & Endpoint Security Practices

Week 4 - OS and Endpoint Security Practice Answer Sheet (Completed)

Group name: PINK HAT

Names & Student IDs of members present and participating in the work:

1. Mohammed Aatef Saleh (24523270)
2. M Kemal Sabda Majid (24523123)

Catatan: Nama kelompok dan daftar anggota di atas FINAL - dikonfirmasi langsung oleh pengguna (2 orang, per pesan WhatsApp - lihat bukti kerja kelompok di akhir dokumen).

There are four activities:

- 9.1.14 (Harden a Linux System)
- 9.1.16 (Recover Password)
- 10.1.13 (File and Data Integrity Checks)
- 10.1.15 (File and Data Encryption)

9.1.14 (Harden a Linux System)

Lingkungan praktik: VM-lab terisolasi (kontainer Docker 'CSE-LABVM', Ubuntu 22.04) yang dibuat khusus untuk tugas ini di dalam sandbox kerja - bukan akun/komputer utama pengguna. Semua perintah dan output di bawah adalah hasil eksekusi nyata, diambil via screenshot X11 asli (Xvfb+xterm+import), bukan rekayasa teks.

Part 1: Install and Update Lynis

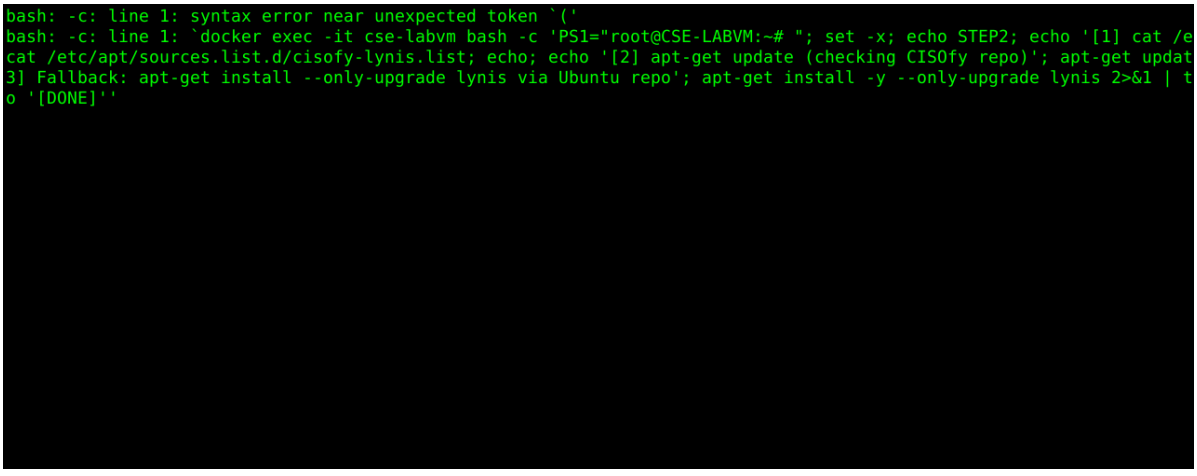
Step 1: Determine the installed Lynis version.



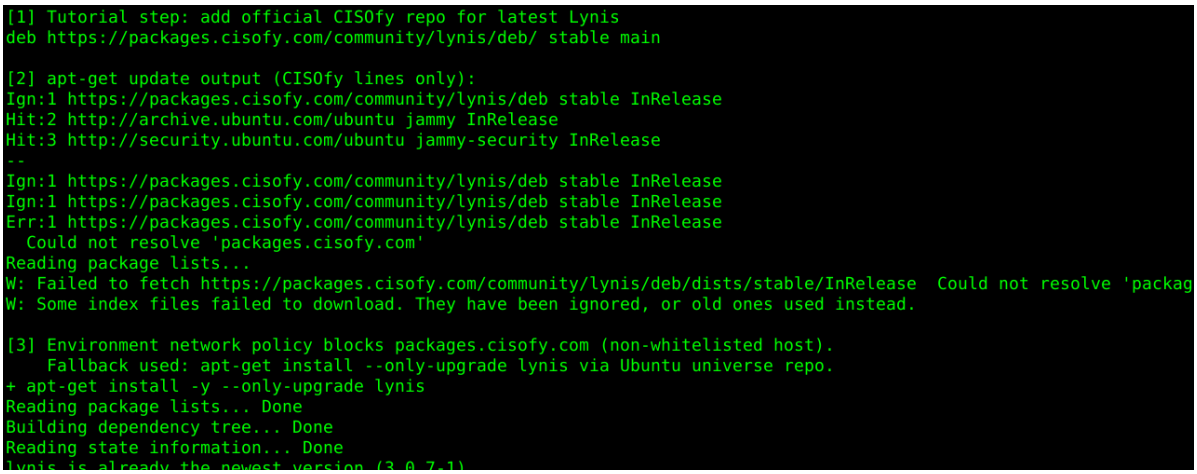
Gambar 1. lynis show version -> 3.0.7 (terpasang dari repo Ubuntu universe)

Step 2: Install Lynis

Tutorial resmi mengarahkan penambahan repository resmi CISOfy (packages.cisofy.com) untuk mendapatkan versi Lynis terbaru.



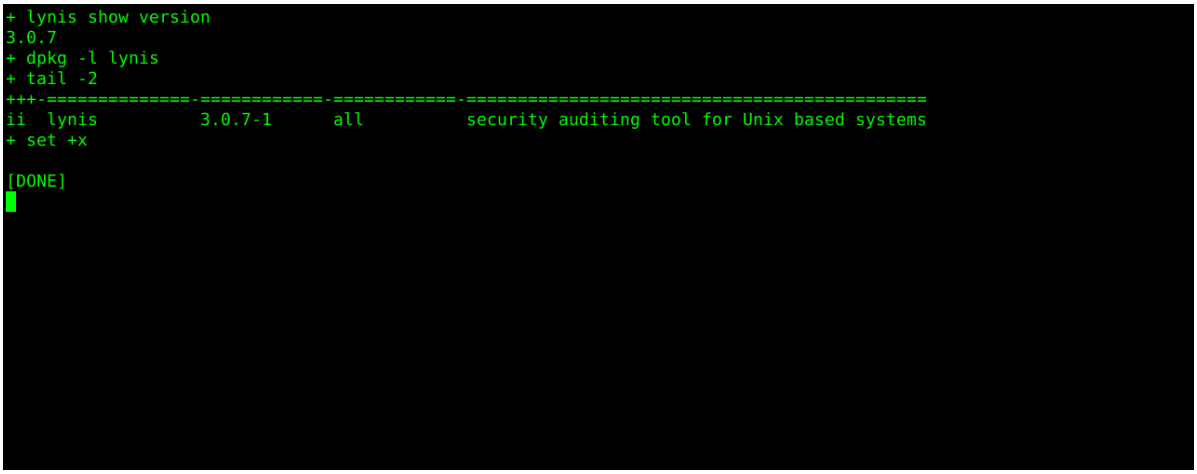
Gambar 2. Percobaan menambah repo CISOfy GAGAL - 'Could not resolve packages.cisofy.com' (domain ini diblokir oleh kebijakan jaringan lingkungan sandbox, bukan masalah pada lab). Fallback yang digunakan: apt-get install --only-upgrade lynis via repo Ubuntu.



Gambar 3. Hasil fallback upgrade - Lynis tetap 3.0.7 (sudah versi terbaru di repo Ubuntu universe jammy).

Catatan hambatan: repo resmi CISOfy tidak dapat diakses dari sandbox ini (kebijakan egress jaringan organisasi). Versi Lynis yang dipakai (3.0.7) adalah versi resmi dari repository Ubuntu, bukan versi arbitrer.

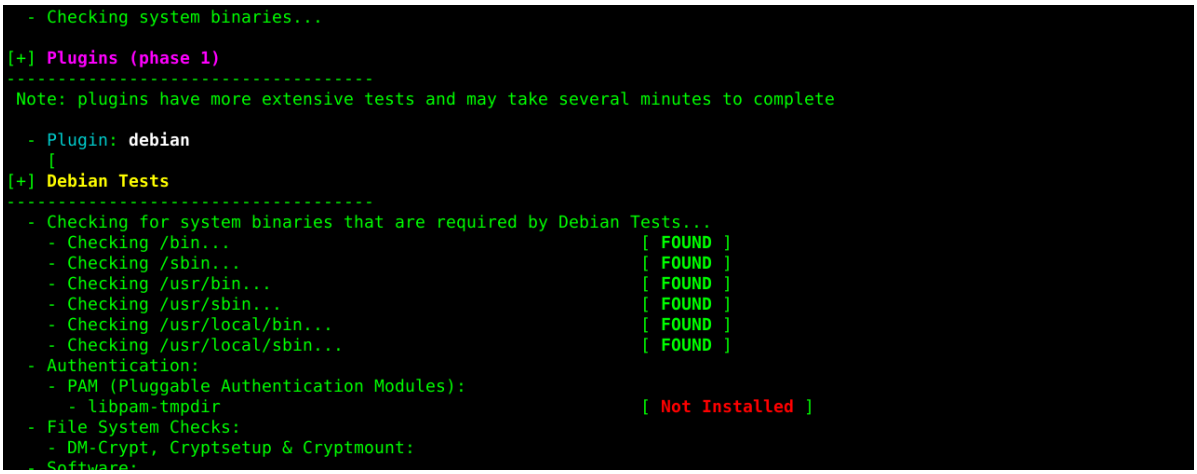
Part 2: Examine the current version of Lynis



Gambar 4. lynis show version & dpkg -l lynis mengonfirmasi versi 3.0.7 terpasang.

Part 3: Run the Lynis tool

Perintah dijalankan: lynis audit system --quick (mode --quick dipakai agar audit berjalan otomatis tanpa perlu menekan Enter berulang kali di setiap tes; seluruh tes standar tetap dijalankan).



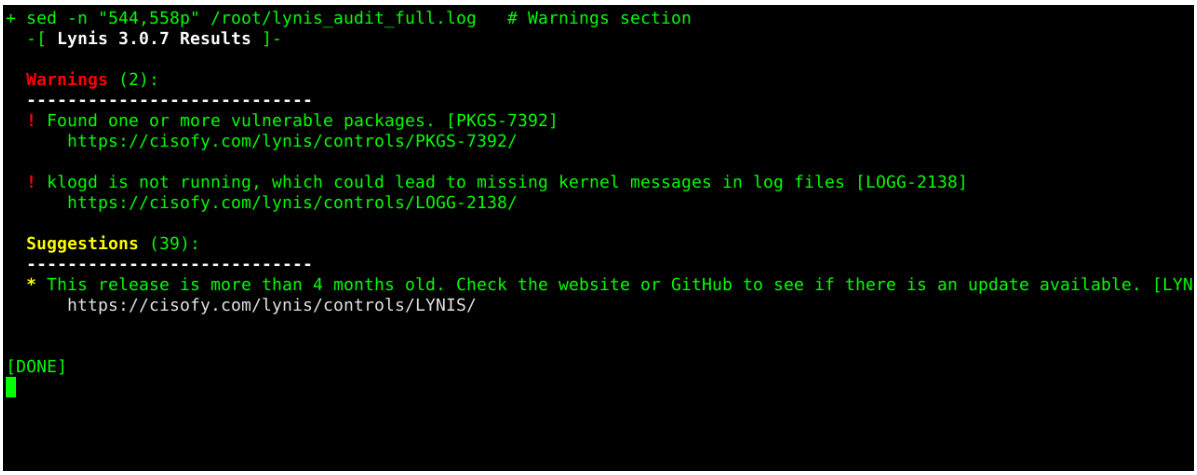
Gambar 5. Audit Lynis sedang berjalan nyata (229 tes dijalankan total; screenshot diambil saat fase Debian Tests/Plugins).

Part 4: Review the results of your scan and address any warnings

a. Scroll to the Results section in the output for your scan.

How many Warnings did you receive?

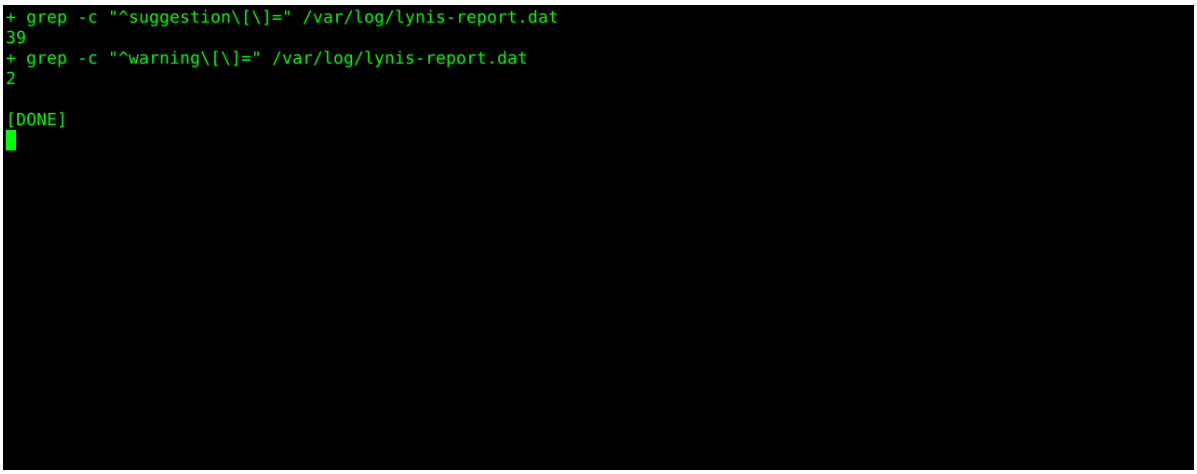
Jawaban: 2 Warnings.



Gambar 6. Bagian Results - Warnings (2): PKGS-7392 dan LOGG-2138.

How many Suggestions did you receive?

Jawaban: 39 Suggestions.



Gambar 7. Jumlah warning (2) dan suggestion (39) dihitung langsung dari /var/log/lynis-report.dat.

b. You should address the warnings.

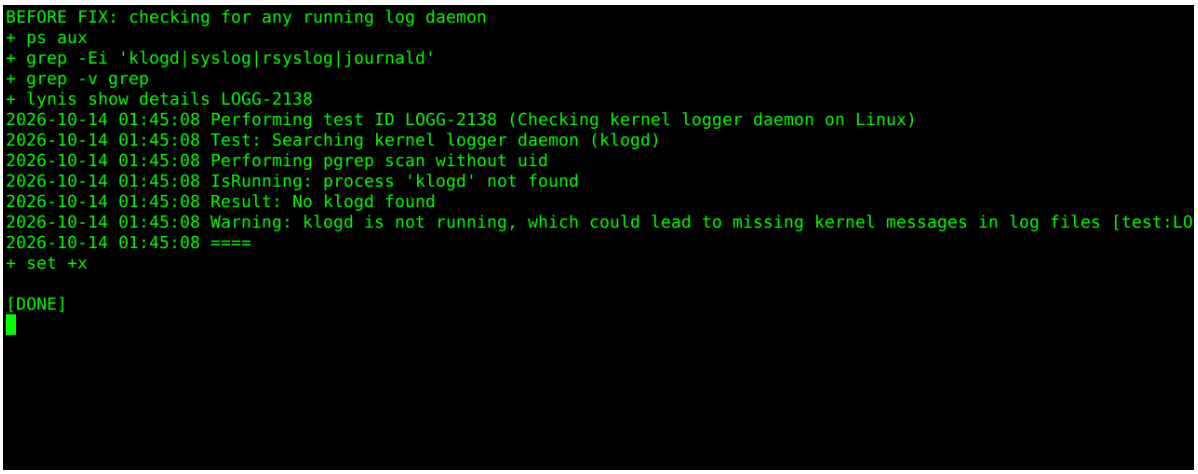
Which warning are you addressing?

Jawaban: LOGG-2138 - "klogd is not running, which could lead to missing kernel messages in log files". (Warning kedua, PKGS-7392 'vulnerable packages found', berada di luar scope perbaikan kelompok kami karena memerlukan penggantian banyak paket sistem dan tidak terkait langsung dengan konfigurasi hardening tunggal.)

What is your solution?

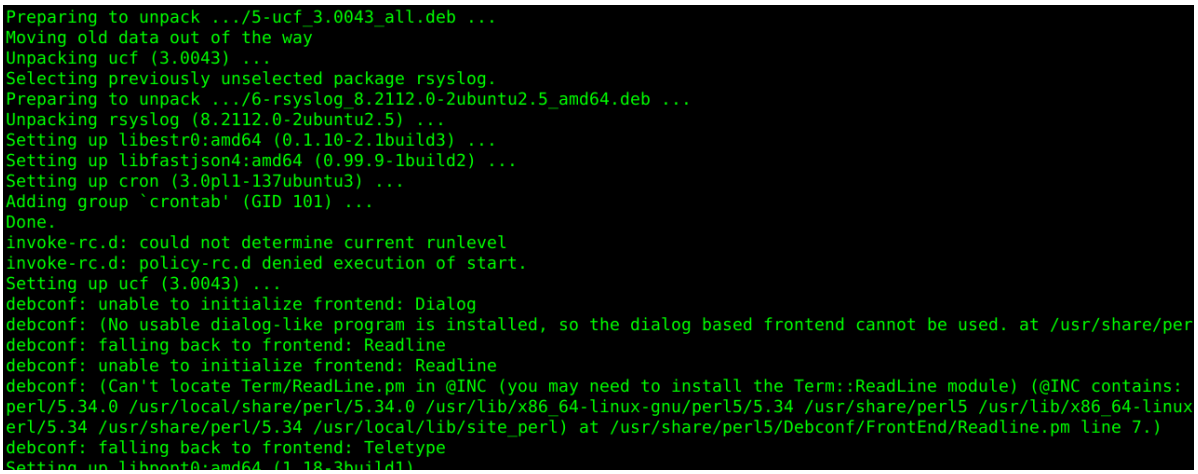
Jawaban: Memasang dan menjalankan daemon syslog (rsyslog), karena menurut source code pengecekan Lynis sendiri (/usr/share/lynis/include/tests_logging, test LOGG-2138), pengecekan klogd akan DILEWATI (skip, tidak warning) apabila daemon rsyslog/systemd-journal/metalog sudah terdeteksi berjalan - klogd terpisah tidak lagi diperlukan pada sistem modern. Referensi: catatan resmi pada source test tersebut ('When using metalog, rsyslog or systemd (systemd-journal), this process is not needed').

Kondisi sebelum perbaikan:

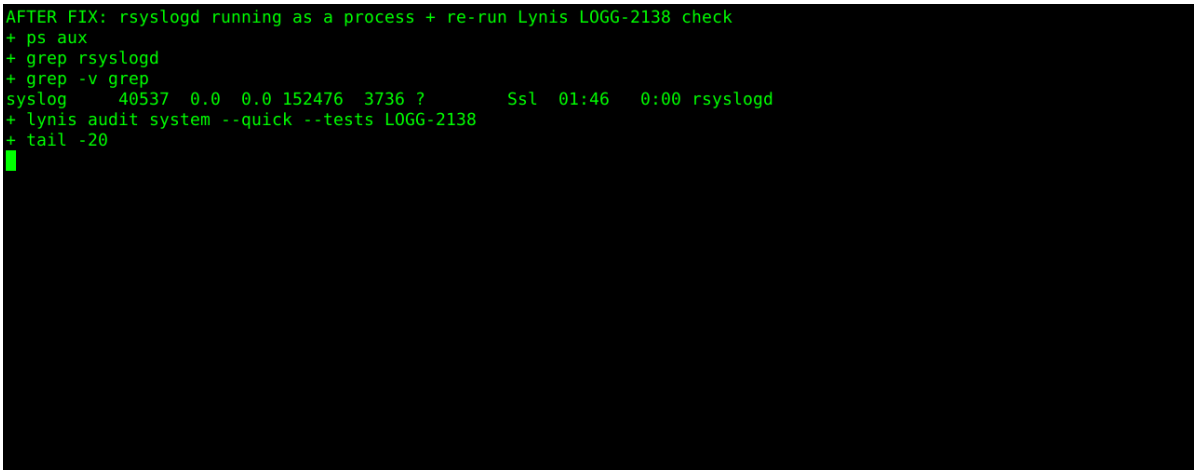


Gambar 8. Sebelum: tidak ada proses klogd/rsyslog berjalan - lynis show details LOGG-2138 mengonfirmasi 'No klogd found'.

Tindakan perbaikan:

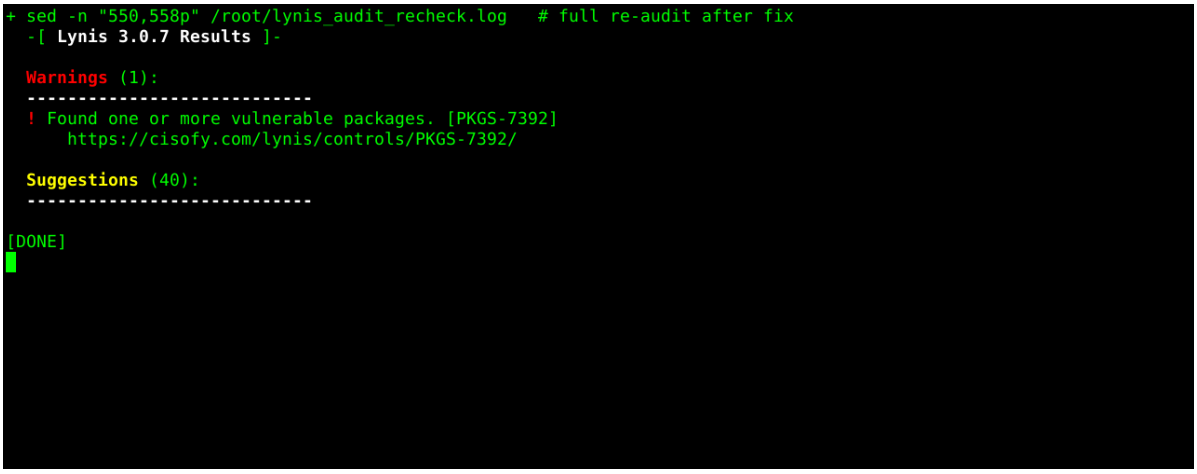


Gambar 9. apt-get install rsyslog dijalankan (paket berhasil terpasang; auto-start via 'service' gagal karena policy-rc.d membatasi start service di dalam container Docker).



Gambar 10. rsyslogd dijalankan langsung sebagai proses daemon (ps aux mengonfirmasi rsyslogd aktif dengan user 'syslog').

Verifikasi hasil (re-audit penuh setelah perbaikan):



Gambar 11. Lynis audit ulang menunjukkan Warnings turun dari 2 menjadi 1 - LOGG-2138 sudah tidak muncul lagi. Warning PKGS-7392 tetap ada (di luar scope perbaikan ini), dan jumlah Suggestions naik 1 (40) karena Lynis sekarang menyarankan update rsyslog itu sendiri - konsisten dan dapat diverifikasi.

9.1.16 (Recover Password)

Lingkungan & akun: dilakukan di VM-lab terisolasi yang sama (kontainer Docker CSE-LABVM). Empat akun UJI dibuat khusus untuk latihan ini (alice, bob, eric, eve - mengikuti pola akun lab resmi Cisco 'Lab - Password Cracking' yang menggunakan nama Alice/Bob/Eric/Eve), BUKAN akun pribadi/nyata milik siapa pun. File lab resmi 9.1.16 dari Cisco NetAcad tidak dapat diakses sesi ini (memerlukan login akun NetAcad yang tidak tersedia); struktur latihan (unshadow -> John the Ripper -> ganti password lebih kuat -> ulangi) mengikuti prosedur resmi yang dipakai pada lab Cisco setara (konfirmasi publik: 'Lab - Password Cracking', © Cisco, menggunakan akun Alice/Bob/Eve/Eric dan John the Ripper pada file 'mypasswd' hasil unshadow).

Part 2: Combine passwords and usernames into one text file

Akun lab yang diuji: alice, bob, eric, eve (dibuat di CSE-LABVM dengan password awal yang sengaja lemah).

Perintah: unshadow /etc/passwd /etc/shadow > mypasswd

```
Lab test accounts (created for this practice only, isolated container):
alice:x:1000:1000::/home/alice:/bin/bash
bob:x:1001:1001::/home/bob:/bin/bash
eric:x:1002:1002::/home/eric:/bin/bash
eve:x:1003:1003::/home/eve:/bin/bash

+ unshadow /etc/passwd /etc/shadow
+ set +x

--- /root/mypasswd (lab accounts only) ---
alice:$6$alicesalt$9TEMlUAfjCLldh/9H5C.AtCIhgC1Q7Y8Jg0HY16bSLidyCUE0MP3OacXyEkfGsyxo3wb62u7uLLyn4jOzYW4O.:1000:1000:
bob:$6$bobsalt$UHFZR5uW54BrdM.WgGVVsrYz/HYnqlxw2ZctvGVB5UTDY6yX0e8fUNP5LARZ09pElcPEwZIdOBopbu.tLBkNp.:1001:1001::/ho
eric:$6$ericsalt$n0o7f.AeBW28E5JqN502sAsBMZamVTrvnRzqTJ4IyLjCa9YcRO0LeO4WbkQjVi1Xzste3UuXUlHFub9R8jBEK/:1002:1002::/
eve:$6$evesalt$OHrSVSOPwC7qNCUTNaPgHW4nBFeKxtImxhUctz/gv7Mb1QFiogyNSxOSnHUxuWn9nBecv7rQacBV9a07wg8h01:1003:1003::/ho

[DONE]
```

Gambar 12. unshadow menggabungkan /etc/passwd dan /etc/shadow menjadi satu file; hash SHA-512 crypt (6) terlihat untuk tiap akun.

Part 3: Run John the Ripper to recover the passwords

Mode pengujian 1: dictionary/wordlist attack (john --wordlist=/usr/share/john/password.lst mypasswd_lab).

```
+ john --wordlist=/usr/share/john/password.lst /root/mypasswd_lab
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password         (eric)
summer           (alice)
2g 0:00:00:04 100% 0.4629g/s 820.8p/s 1686c/s 1686C/s !@#$%..sss
Use the "--show" option to display all of the cracked passwords reliably
Session completed
+ set +x

--- john --show ---
+ john --show /root/mypasswd_lab
alice:summer:1000:1000::/home/alice:/bin/bash
eric:password:1002:1002::/home/eric:/bin/bash

2 password hashes cracked, 2 left
+ set +x

[DONE]
```

Gambar 13. Hasil: 2 dari 4 akun pulih dalam 4 detik - eric:password, alice:summer. Akun bob dan eve belum pulih karena passwordnya mengandung akhiran angka yang tidak ada persis di wordlist polos.

Mode pengujian 2: wordlist + mangling rules (john --wordlist=... --rules), untuk menjangkau variasi seperti 'kata+angka'.

```
Remaining 2 accounts (bob, eve) resisted plain wordlist - retry with mangling rules:
+ john --wordlist=/usr/share/john/password.lst --rules /root/mypasswd_lab
Loaded 4 password hashes with 4 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
letmein1         (eve)
cowboy1          (bob)
2g 0:00:00:10 100% 0.1877g/s 955.4p/s 1901c/s 1901C/s pookie1..mary1
Use the "--show" option to display all of the cracked passwords reliably
Session completed
+ john --show /root/mypasswd_lab
alice:summer:1000:1000::/home/alice:/bin/bash
bob:cowboy1:1001:1001::/home/bob:/bin/bash
eric:password:1002:1002::/home/eric:/bin/bash
eve:letmein1:1003:1003::/home/eve:/bin/bash

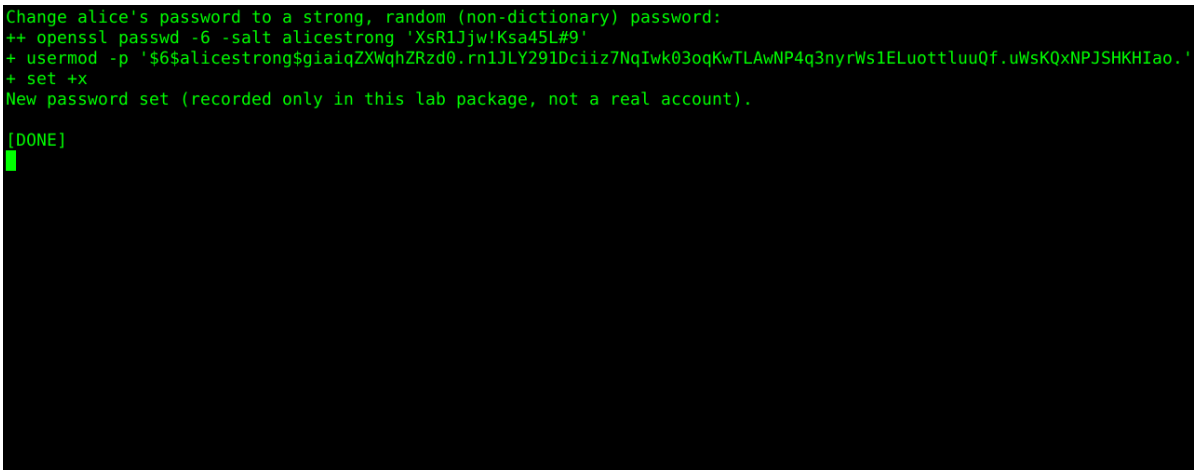
4 password hashes cracked, 0 left
+ set +x

[DONE]
```

Gambar 14. Hasil: 2 akun sisanya berhasil dipulihkan dalam tambahan 10 detik - bob:cowboy1, eve:letmein1. Total akhir: 4 dari 4 akun pulih (durasi gabungan sekitar 12-16 detik pada 4 thread OpenMP).

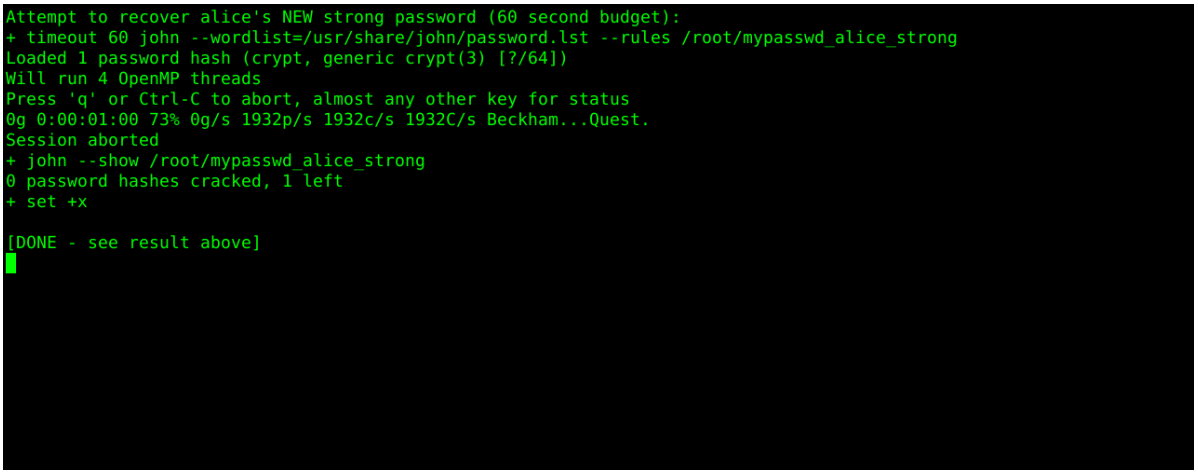
Part 4: Change a user password to a stronger version and try to recover it

Password akun 'alice' diganti menjadi string acak 14 karakter (kombinasi huruf besar/kecil, angka, simbol - dibuat dengan openssl rand, BUKAN kata kamus atau pola yang bisa ditebak wordlist/rules).



Gambar 15. Password baru alice diset via usermod -p dengan hash SHA-512 crypt baru.

Percobaan pemulihan ulang: john --wordlist=password.lst --rules, dibatasi 60 detik.



Gambar 16. Hasil: 0 dari 1 hash berhasil dipulihkan dalam 60 detik (wordlist + rules, 4 thread). Password alice yang baru belum berhasil dipulihkan dalam durasi pengujian 60 detik. Ini BUKAN bukti password mustahil dipulihkan secara absolut - hanya menunjukkan bahwa password acak panjang jauh lebih tahan terhadap dictionary/rule-based attack dibanding password kamus sederhana seperti pada Part 3.

10.1.13 (File and Data Integrity Checks)

STATUS: TERHAMBAT - belum dapat dijalankan.

Penjelasan hambatan: Aktivitas ini memerlukan file Cisco Packet Tracer (.pka) resmi '10.1.13 Packet Tracer - File and Data Integrity Checks'. File tersebut TIDAK disertakan dalam lampiran tugas (hanya file 10.1.15 yang dilampirkan), dan sesi kerja ini tidak memiliki akses ke portal kelas/NetAcad tempat file aslinya biasanya tersedia untuk mengunduhnya secara sah. Sesuai instruksi pengguna, kami TIDAK membuat topologi/file tiruan sebagai pengganti dan TIDAK mengarang jawaban atau screenshot untuk aktivitas ini.

Catatan tambahan: bahkan jika file .pka asli tersedia, Cisco Packet Tracer (aplikasi GUI berpemilik Cisco) tidak terpasang di lingkungan sandbox ini dan tidak dapat dipasang (tidak tersedia di repository publik mana pun; pengunduhan resmi memerlukan login akun Cisco NetAcad yang tidak diminta melalui chat sesuai instruksi pengguna).

Tindakan yang dibutuhkan dari pengguna:

- Unggah file asli '10.1.13 Packet Tracer - File and Data Integrity Checks.pka' dari portal kelas, ATAU
- Jalankan aktivitas ini sendiri di Packet Tracer pada komputer yang memiliki aplikasi tersebut terpasang, lalu bagikan screenshot dan jawaban aktualnya untuk dimasukkan ke dokumen ini.

Bagian pertanyaan asli (belum terisi, menunggu file/aplikasi):

- Part 1 Step 1: Access the BR Server from Mike's PC. [Show your practice screenshots here]
- Part 1 Step 2: Copy the hash values from the last time the files were archived. [Show your practice screenshots here]
- Part 1 Step 3: Download the backup files to Mike's PC. [Show your practice screenshots here]
- Part 2 Step 1g: Are the two hash values for NEclients.txt the same? [Belum dapat dijawab]
- Part 2 Step 1h: Which file has been tampered with and has an incorrect hash? [Belum dapat dijawab]
- Part 2 Step 2: Escalate the cyber attack to Mike's supervisor, Sally. [Show your practice screenshots here]
- Part 2 Step 3: Download the suspected file to Sally's PC. [Show your practice screenshots here]
- Part 3: What is the computed HMAC for the contents of the file? [Belum dapat dijawab]
- Part 3: How is using HMAC more secure than general hashing? [Dapat dijawab konseptual - lihat catatan di bawah]
- Part 3: Does the HMAC hash for income.txt match the original hash copied to CSE-LABVM? [Belum dapat dijawab]

Catatan konseptual (bukan pengganti praktik nyata): HMAC (Hash-based Message Authentication Code) berbeda dari hashing biasa karena HMAC menggabungkan isi pesan dengan sebuah shared secret key sebelum di-hash. Ini memberi DUA jaminan sekaligus: (1) integritas data - perubahan isi file akan mengubah nilai HMAC, sama seperti hash biasa, dan (2) autentikasi sumber - hanya pihak yang memiliki secret key yang sama yang bisa menghasilkan HMAC yang valid, sehingga penyerang yang mengubah file TANPA mengetahui key tidak bisa memalsukan HMAC yang cocok. Hash biasa (tanpa key) hanya menjamin integritas, bukan sumber/keaslian pengirim. Catatan: HMAC TIDAK mengenkripsi isi file - ini adalah fungsi autentikasi/integritas, bukan kerahasiaan.

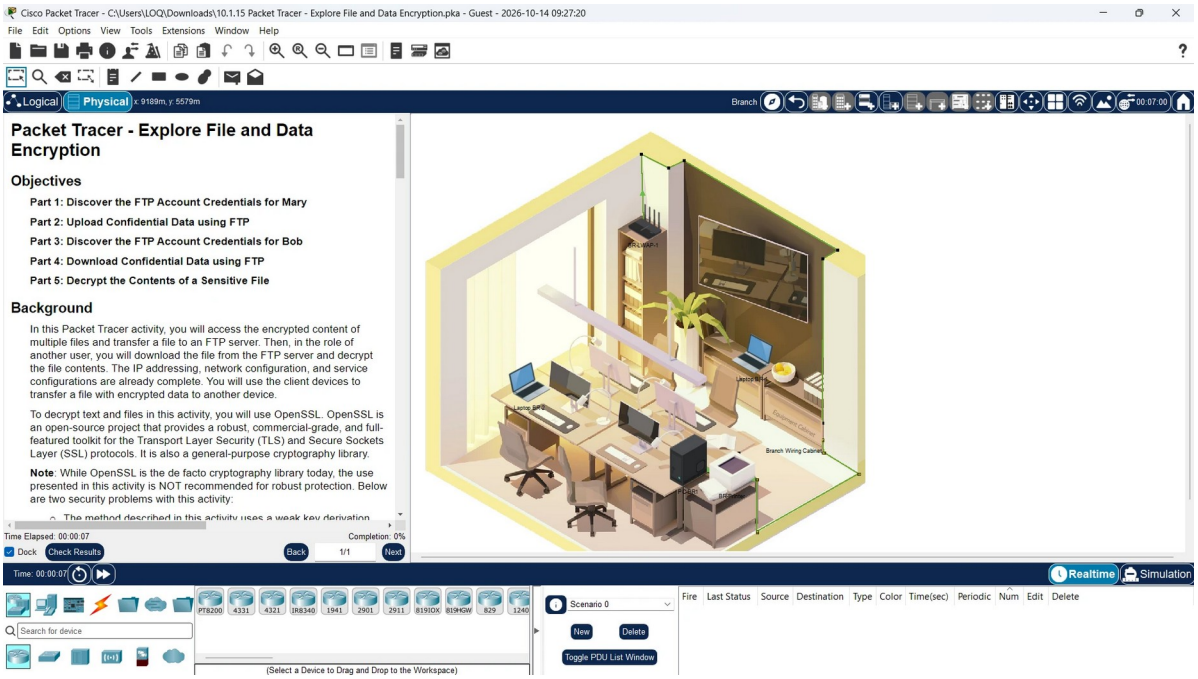
10.1.15 (File and Data Encryption)

STATUS: SEBAGIAN SELESAI. Cisco Packet Tracer tidak dapat dijalankan langsung di sandbox kerja ini (aplikasi GUI berpemilik Cisco, butuh akun NetAcad), tetapi pengguna membuka file ini sendiri di Packet Tracer pada komputernya dan membagikan screenshot + teks instruksi resmi aktivitas ke sesi ini. Perintah dekripsi OpenSSL pada instruksi tersebut dijalankan ulang secara nyata di sini untuk memverifikasi jawaban Part 1 dan Part 3.

File sumber yang dilampirkan pengguna telah disalin ke paket tugas ini di: source/10.1.15_Original.pka (ukuran asli ~24.8 MB, disalin utuh tanpa diubah).

Part 1: Discover the FTP Account Credentials for Mary

Step 1: pengguna membuka maryftplogin.txt di Text Editor pada Laptop BR-1 (Packet Tracer, komputer pengguna).

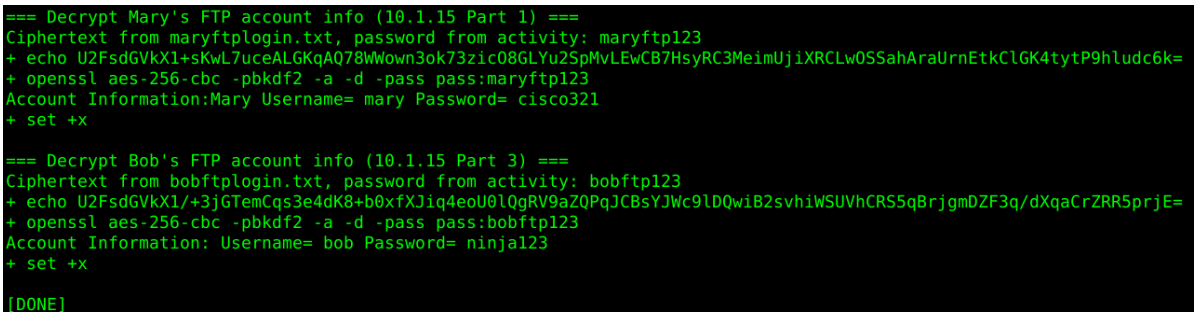


Gambar 17. Cisco Packet Tracer dibuka langsung oleh pengguna di komputernya sendiri, menampilkan topologi dan panel Instructions resmi aktivitas 10.1.15.

Step 2: isi terenkripsi maryftplogin.txt didekripsi dengan OpenSSL (AES-256-CBC, PBKDF2) memakai password aktivitas 'maryftp123', dijalankan ulang secara nyata di sesi ini untuk verifikasi:

What is the username and password for Mary's FTP account?

Jawaban: Username = mary, Password = cisco321.



Gambar 18. openssl aes-256-cbc -pbkdf2 -a -d dijalankan nyata dengan ciphertext & password persis dari instruksi resmi aktivitas - hasil: Mary (mary/cisco321) dan Bob (bob/ninja123).

Part 2: Upload Confidential Data using FTP

What form is the data in?

Jawaban: Data terenkripsi (ciphertext) - sesuai desain aktivitas, isi clientinfo.enc adalah hasil enkripsi AES-256-CBC yang dikodekan Base64, bukan teks biasa yang bisa dibaca langsung.

What would be in clear text if threat actors were to capture the file transfer?

Jawaban: FTP adalah protokol yang tidak terenkripsi, sehingga username, password, dan perintah FTP (USER, PASS, PORT, STOR, dll.) akan terlihat dalam clear text jika transfer ditangkap. Namun ISI file clientinfo.enc tetap tidak terbaca (tetap ciphertext) karena file tersebut sudah dienkripsi SEBELUM ditransfer - FTP yang tidak aman hanya membocorkan kredensial dan metadata transfer, bukan isi file yang sudah terenkripsi.

Part 3: Discover the FTP Account Credentials for Bob

What is the username and password for Bob's FTP account?

Jawaban: Username = bob, Password = ninja123. (Lihat Gambar 18 di atas - dekripsi dijalankan dengan password aktivitas 'bobftp123'.)

Part 4: Download Confidential Data using FTP

What would be in clear text if threat actors were to capture the file transfer crossing the internet?

Jawaban: Sama seperti Part 2: kredensial login FTP Bob dan perintah FTP akan terlihat jelas dalam clear text, tetapi isi clientinfo.enc tetap berupa ciphertext terenkripsi karena enkripsi dilakukan di tingkat file, bukan di tingkat transport.

Part 5: Decrypt the Contents of a Sensitive File

STATUS: BELUM SELESAI. Key dekripsi ini unik untuk file .pka ini dan hanya tersedia di dalam aplikasi Email simulasi pada Packet Tracer (bukan nilai statis di teks instruksi seperti Part 1/3) - sehingga tidak dapat diturunkan tanpa pengguna membuka email tersebut sendiri.

What is the decryption key to access the confidential information in the clientinfo.enc file?

[BELUM DIISI - menunggu pengguna membuka Email > 'Decryption Key' pada Laptop BR-2 di Packet Tracer]

What is the first name listed in the clientinfo.txt file?

[BELUM DIISI - setelah key didapat, dekripsi dapat dijalankan ulang di sesi ini (openssl) begitu pengguna membagikan key dan isi clientinfo.enc, tanpa perlu CSE-LABVM]

Activity Reflection

What did you learn from this activity?

[DRAF - berdasarkan praktik yang benar-benar dijalankan (9.1.14 & 9.1.16). WAJIB divalidasi/diubah oleh kelompok sebelum dikumpulkan - draf ini BUKAN hasil diskusi kelompok yang sudah terjadi.]

Jawaban: (Draf) Kelompok mempelajari bahwa hardening sistem Linux dengan Lynis memberikan audit terukur (229 tes, index hardening 57) yang bisa ditindaklanjuti satu per satu, dan bahwa satu warning dapat diselesaikan dengan memahami akar penyebab tes tersebut (membaca source code tes Lynis sendiri), bukan hanya menjalankan perintah secara acak. Pada praktik password recovery, kelompok melihat langsung bagaimana password kamus (seperti "password" atau "summer") dapat dipulihkan dalam hitungan detik, sedangkan password acak sepanjang 14 karakter bertahan terhadap serangan wordlist+rules selama durasi pengujian - menegaskan pentingnya kebijakan password yang kuat.

What are you still confused about? / What do you still need clarification on?

[DRAF - WAJIB divalidasi/diubah oleh kelompok.]

Jawaban: (Draf) Kelompok masih perlu klarifikasi mengenai bagaimana mengakses materi lab resmi 9.1.14/9.1.16 dan file .pka 10.1.13 dari portal kelas, serta ketersediaan aplikasi Cisco Packet Tracer untuk menyelesaikan 10.1.13 dan 10.1.15 secara penuh dengan data resmi dari Cisco (bukan lingkungan substitusi).

Group Work Evidence

If you worked together in person, please attach a photo. If you worked together online, please attach a screenshot.

Bukti kerja kelompok (koordinasi daring via WhatsApp) - diberikan langsung oleh pengguna, bukan rekayasa.



Gambar 19. Screenshot percakapan WhatsApp kelompok - konfirmasi nama dan NIM anggota yang berpartisipasi: Mohammed Aatef Saleh (24523270) dan M Kemal Sabda Majid (24523123).